DEVSECOPS CAPSTONE · OCTOBER 2026

PantryPulse

Stock, expiry and dispatch tracking for community food banks — shipped through a gated, observable, GitOps-driven delivery platform.

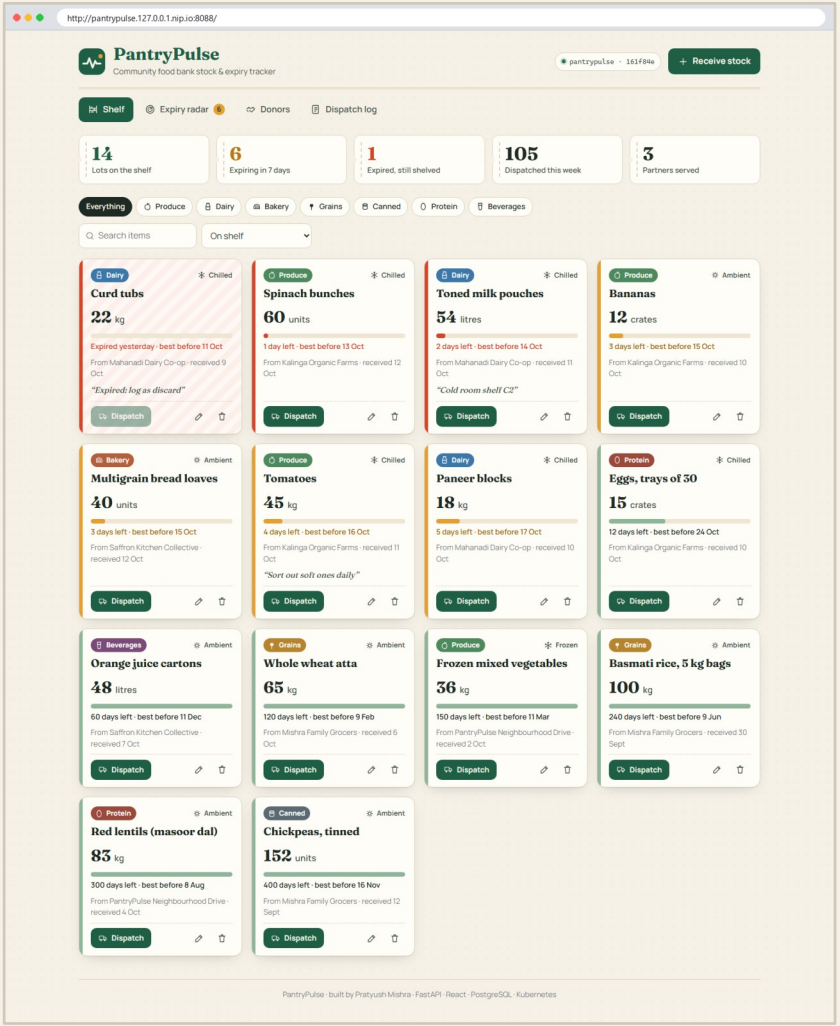
Pratyush Mishra

github.com/PratyushMishra-2nd/DevopsProject

THE APPLICATION

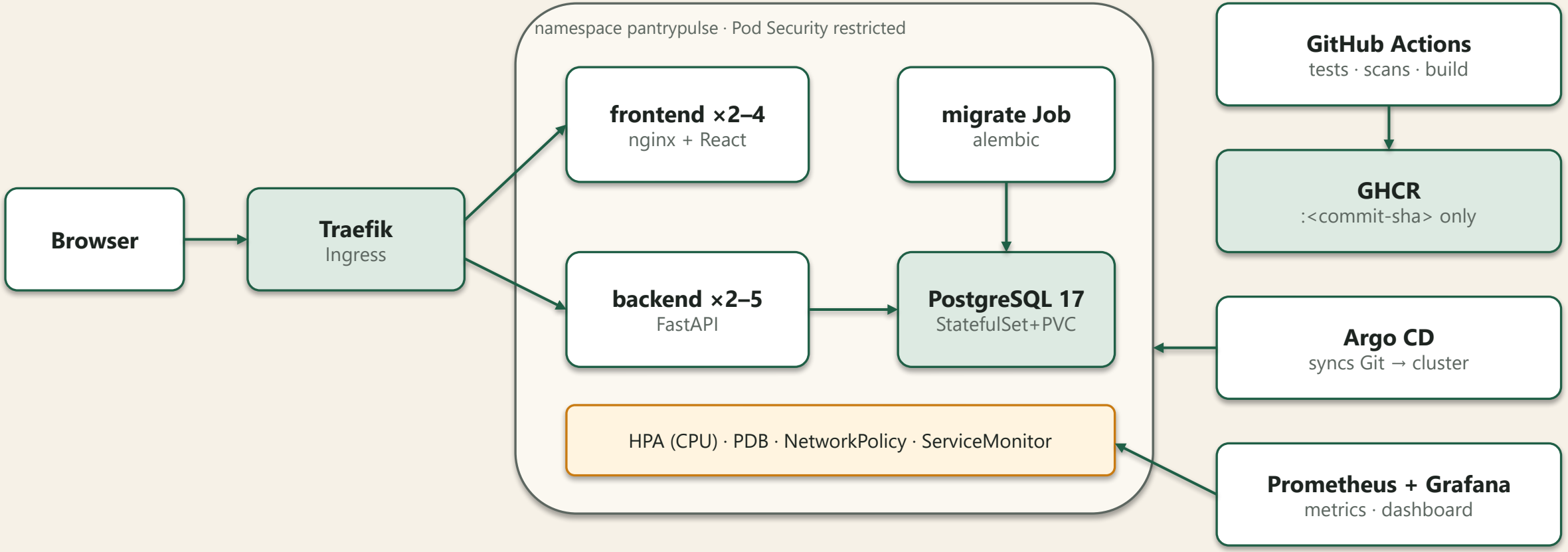
What PantryPulse does

- Shelf: every lot with a freshness bar and KPIs
- Expiry radar: what to move first
- Donors and a dispatch log to partner shelters
- Business rules enforced by the API
  - over-dispatch → 422, expired/held lot → 409
  - lot with dispatch history cannot be deleted → 409
  - voiding a dispatch restores the quantity
- Version badge shows the deployed commit SHA



ARCHITECTURE

Three tiers, one chart, many gates



Same Helm chart everywhere: CI's throwaway kind cluster, the local GitOps environment, and the EKS profile (values-eks.yaml).

TECHNOLOGY

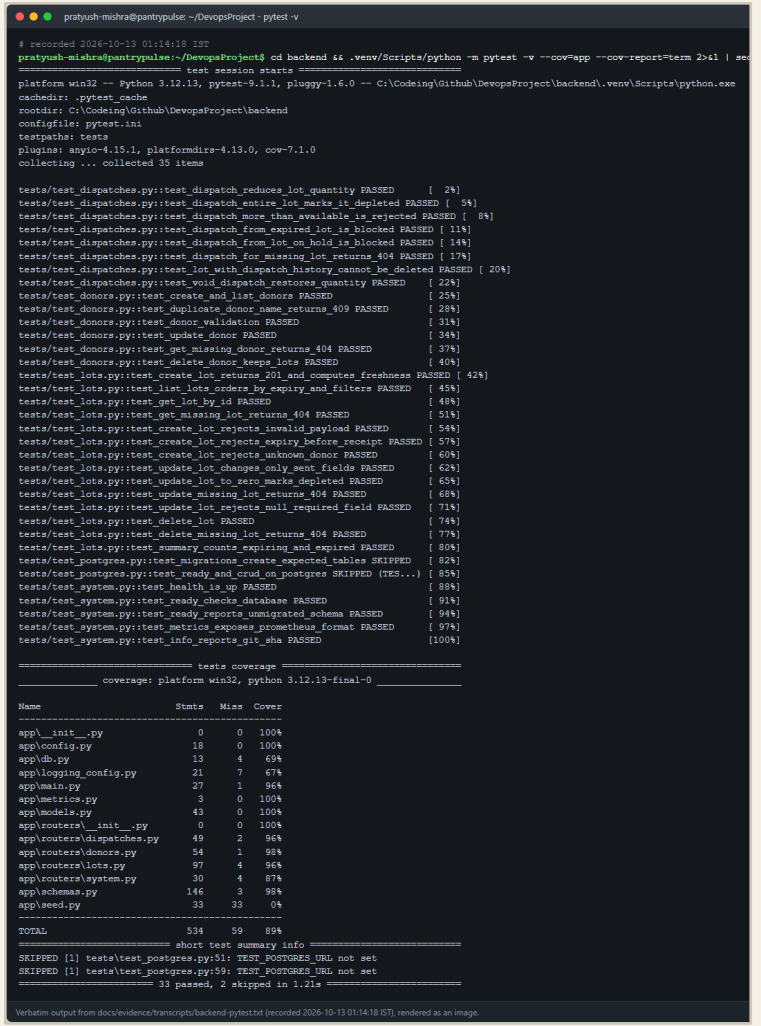
Stack and why

App	FastAPI · SQLAlchemy 2 · Alembic · React 19 + Vite · PostgreSQL 17
Quality	pytest (89% cov) · vitest · ruff · eslint/prettier
Security	bandit · pip-audit · npm audit · gitleaks · Trivy image + IaC · SBOM · provenance
Delivery	Docker multi-stage · GitHub Actions · GHCR (SHA tags) · Argo CD
Platform	Terraform → AWS VPC + EKS 1.35 · kind 1.37 · Helm 4 · Traefik 3.7 · HPA
Observe	Prometheus · Grafana 13 · ServiceMonitor · JSON logs

7 ADRs · e.g. Traefik instead of ingress-nginx (retired upstream March 2026)

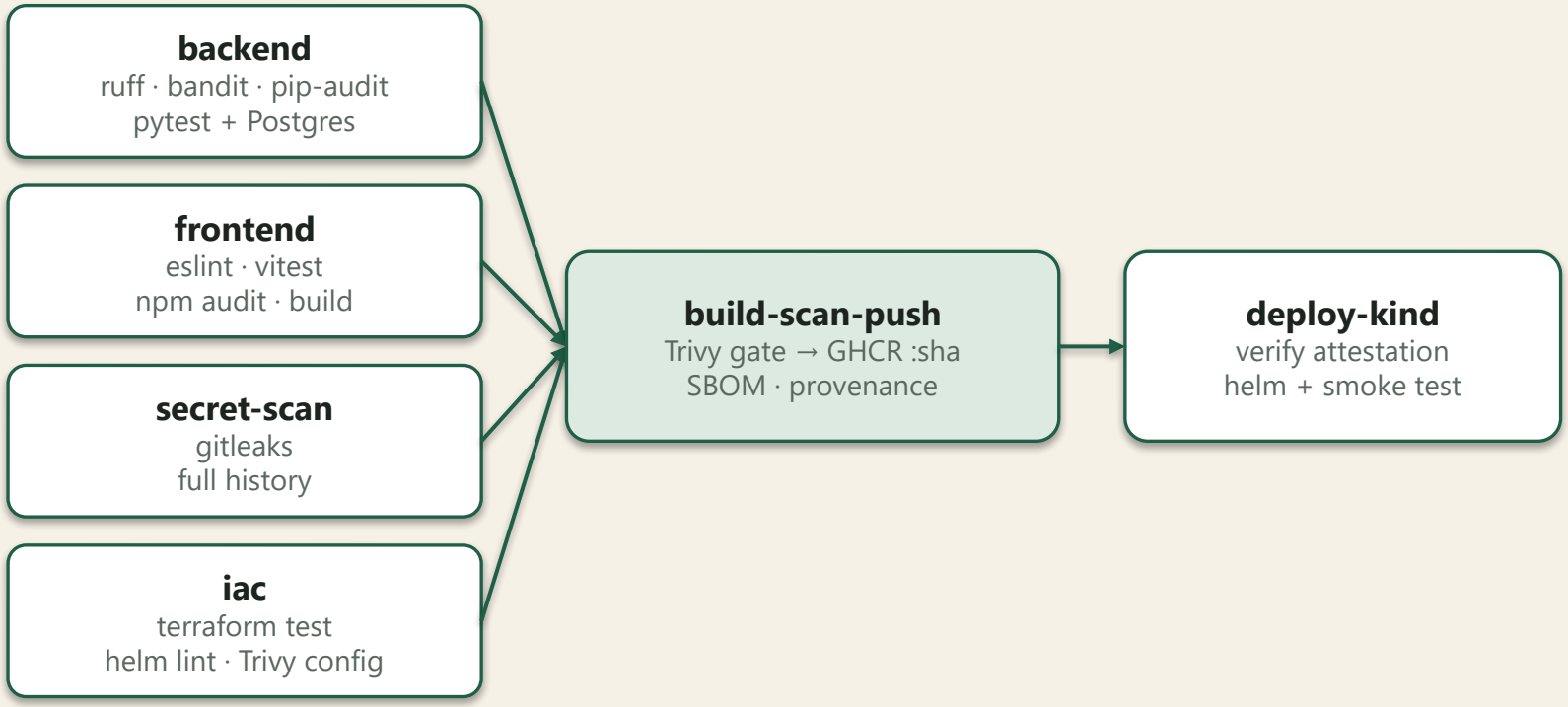
Tests, quality and containers

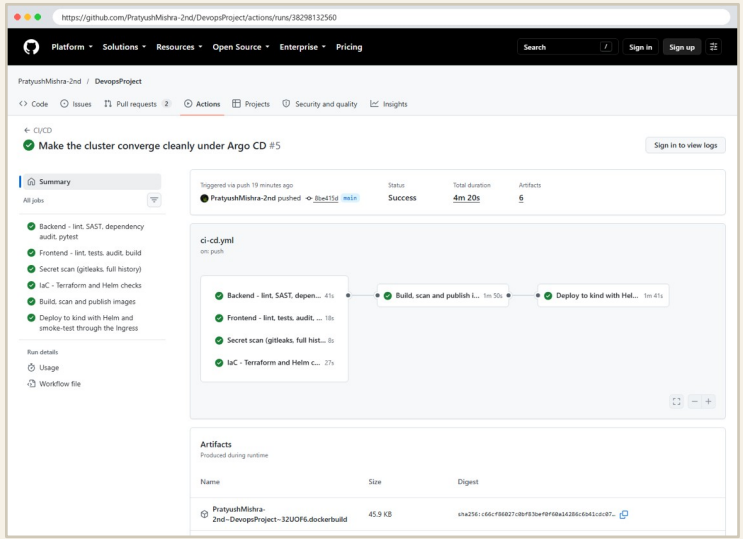
- 33 pytest + 2 PostgreSQL integration tests, 89% coverage
  - SQLite in-memory via dependency override; never the real DB
- 15 vitest tests for the UI
- Backend: python:3.12-slim-trixie, 2-stage, UID 10001
- Frontend: Node build → nginx-unprivileged, UID 101
- Compose: health-gated start, named volume, migrations + seed



M5

CI/CD: nothing ships unless every gate passes





Run 38298132560: 6/6 green. Run 38282550447 failed for real (Traefik values schema) and was fixed in 54a966e.

All actions pinned by commit SHA · least-privilege job permissions · PRs never publish

M6

DevSecOps: a clean Trivy gate, and why it is clean

pratyush-mishra@pantrypulse: ~/DevopsProject - Trivy gate in CI run 38298132560 (gh run view --log)

```
pratyush-mishra@pantrypulse:~/DevopsProject$ gh run view 38298132560 --log --job 114974385509 | awk -F'\t' '$2 ~ /^(Trivy scan|Full vulnerability|Push images)/ {sub(/^[0-9T:.-]+Z
?/, "", $3); if ($3 !~ /MiB|^[0-9T:.-]+Z$|^$|##\[/) print $2 " | " $3}'
Trivy scan - backend image (gate) | trivy image --exit-code 1 --severity HIGH,CRITICAL --ignore-unfixed \
Trivy scan - backend image (gate) |   --scanners vuln,secret --format table "${IMAGE_PREFIX}-backend:${GITHUB_SHA}" | tee trivy-backend.txt
Trivy scan - backend image (gate) | Report Summary
Trivy scan - backend image (gate) |
Trivy scan - backend image (gate) | ┌──────────────────────────────────────────────────────────────────────────┬────────┬─────────────────┬─────────┐
Trivy scan - backend image (gate) | │                                  Target                                  │  Type  │ Vulnerabilities │ Secrets │
Trivy scan - backend image (gate) | │ ghcr.io/pratyushmishra-2nd/pantrypulse-backend:8be415d7e29164a997390aad36d32623- │ debian │        0        │    -    │
Trivy scan - backend image (gate) | │ c3548548 (debian 13.7)                                                   │        │                 │         │
Trivy scan - backend image (gate) | └──────────────────────────────────────────────────────────────────────────┴────────┴─────────────────┴─────────┘
Trivy scan - backend image (gate) | Legend:
Trivy scan - backend image (gate) | - '0': Clean (no security findings detected)
Trivy scan - frontend image (gate) | trivy image --exit-code 1 --severity HIGH,CRITICAL --ignore-unfixed \
Trivy scan - frontend image (gate) |   --scanners vuln,secret --format table "${IMAGE_PREFIX}-frontend:${GITHUB_SHA}" | tee trivy-frontend.txt
Trivy scan - frontend image (gate) | Report Summary
Trivy scan - frontend image (gate) |
Trivy scan - frontend image (gate) | ┌──────────────────────────────────────────────────────────────────────────┬────────┬─────────────────┬─────────┐
Trivy scan - frontend image (gate) | │                                  Target                                  │  Type  │ Vulnerabilities │ Secrets │
Trivy scan - frontend image (gate) | │ ghcr.io/pratyushmishra-2nd/pantrypulse-frontend:8be415d7e29164a997390aad36d3262- │ alpine │        0        │    -    │
Trivy scan - frontend image (gate) | │ 3c3548548 (alpine 3.24.2)                                                │        │                 │         │
Trivy scan - frontend image (gate) | └──────────────────────────────────────────────────────────────────────────┴────────┴─────────────────┴─────────┘
Trivy scan - frontend image (gate) | Legend:
Trivy scan - frontend image (gate) | - '0': Clean (no security findings detected)
Push images tagged with the commit SHA |   digest=$(docker buildx imagetools inspect "${IMAGE_PREFIX}-$c:${GITHUB_SHA}" --format '{{ .Manifest.Digest }}')
Push images tagged with the commit SHA |   echo "${c}_digest=$digest" >> "$GITHUB_OUTPUT"
Push images tagged with the commit SHA |   echo "- \`${IMAGE_PREFIX}-$c:${GITHUB_SHA}\` @ \`$digest\`" >> "$GITHUB_STEP_SUMMARY"
Push images tagged with the commit SHA | 773d4893ec90: Pushed
Push images tagged with the commit SHA | b430d0fca5da: Pushed
Push images tagged with the commit SHA | 0c43ac2b91bc: Pushed
Push images tagged with the commit SHA | 4513ea68e53c: Pushed
Push images tagged with the commit SHA | dca2a125b490: Pushed
Push images tagged with the commit SHA | af16d4892134: Pushed
Push images tagged with the commit SHA | 2f769aad972a: Pushed
Push images tagged with the commit SHA | e1fa2746ad6d: Pushed
Push images tagged with the commit SHA | b361fa3b9794: Pushed
Push images tagged with the commit SHA | a84e8b5ccab8: Pushed
Push images tagged with the commit SHA | 15f1c8eb1ab1: Pushed
Push images tagged with the commit SHA | 8be415d7e29164a997390aad36d32623c3548548: digest: sha256:3e50710b8dfdf4b10fe2cbc6c90b37ce6e7780081ef642c6eca43250d92da624 size: 2619
Push images tagged with the commit SHA | 0d53eba7f7b1: Pushed
Push images tagged with the commit SHA | 10a6a0362e3d: Pushed
Push images tagged with the commit SHA | abc1ca7f858c: Pushed
Push images tagged with the commit SHA | 37b782fd886c: Pushed
Push images tagged with the commit SHA | b53268e3e841: Pushed
Push images tagged with the commit SHA | 8632be6b207b: Pushed
Push images tagged with the commit SHA | ef2d57c4733b: Pushed
Push images tagged with the commit SHA | 049faeb62ee0: Pushed
Push images tagged with the commit SHA | f4bb89e37787: Pushed
Push images tagged with the commit SHA | d95f58cfc01b: Pushed
Push images tagged with the commit SHA | 2e8009e0b40f: Pushed
Push images tagged with the commit SHA | 8be415d7e29164a997390aad36d32623c3548548: digest: sha256:47c17ce4006bbd5a9514ed319bb32b36ee3a07bd3b7bfa054ff844365184cd2f size: 2824
```

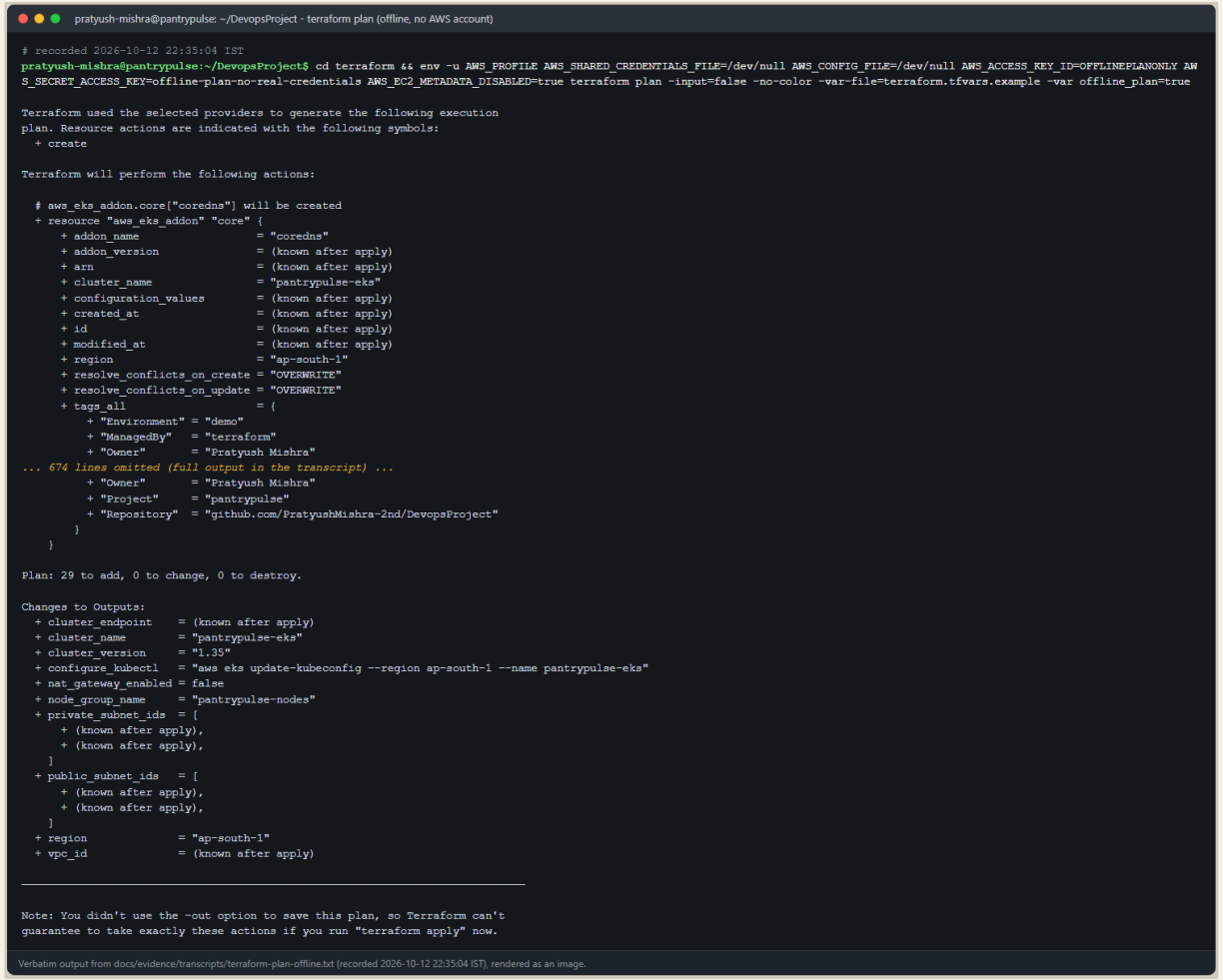
Selected lines (commands plus matching output lines) from docs/evidence/transcripts/ci-trivy-gate.txt (recorded 2026-10-13 01:18:36 IST), rendered as an image.

- trivy image --exit-code 1 --severity HIGH,CRITICAL --ignore-unfixed
- Result: 0 / 0 (Debian 13.7, Alpine 3.24.2)
- Why clean: slim/alpine bases, no build tools at runtime, pinned + Dependabot
- Also: gitleaks, bandit, pip-audit, npm audit, Trivy IaC
- Runtime: non-root, read-only rootfs, PSA restricted, NetworkPolicy

M7

Terraform: AWS VPC + EKS, as code

- VPC 10.42.0.0/16 · 2 public + 2 private subnets (ap-south-1a/b)
- EKS 1.35 · node group t3.medium × 2 (1–3)
- IAM · add-ons · EBS CSI via Pod Identity
- API endpoint limited to your /32
- NAT / KMS / logs behind cost switches (ADR 0003)
- init · validate · test (4 pass) · plan: 29 to add

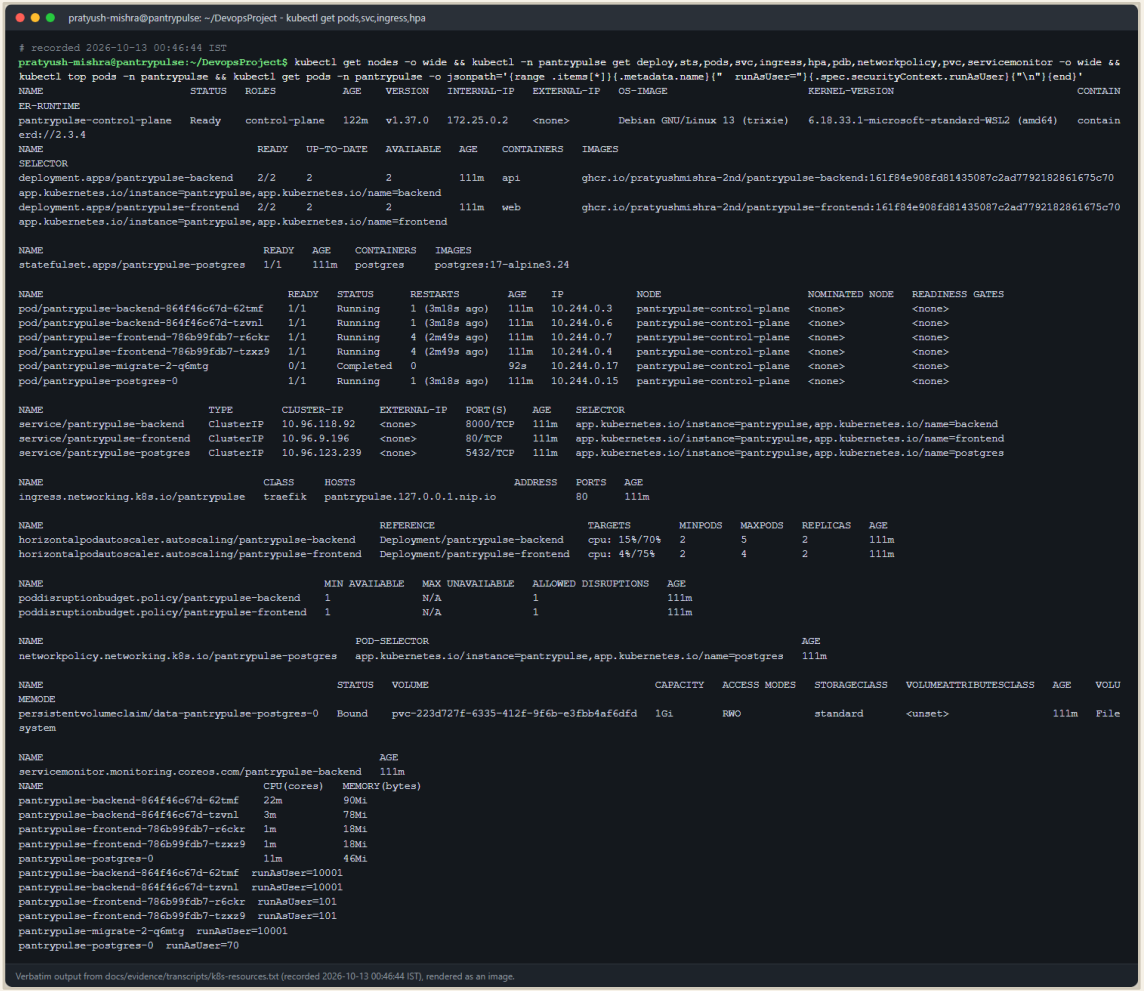


AWS status: PENDING EXTERNAL ACCESS

Not applied: no valid AWS credentials. No console screenshots.

M8

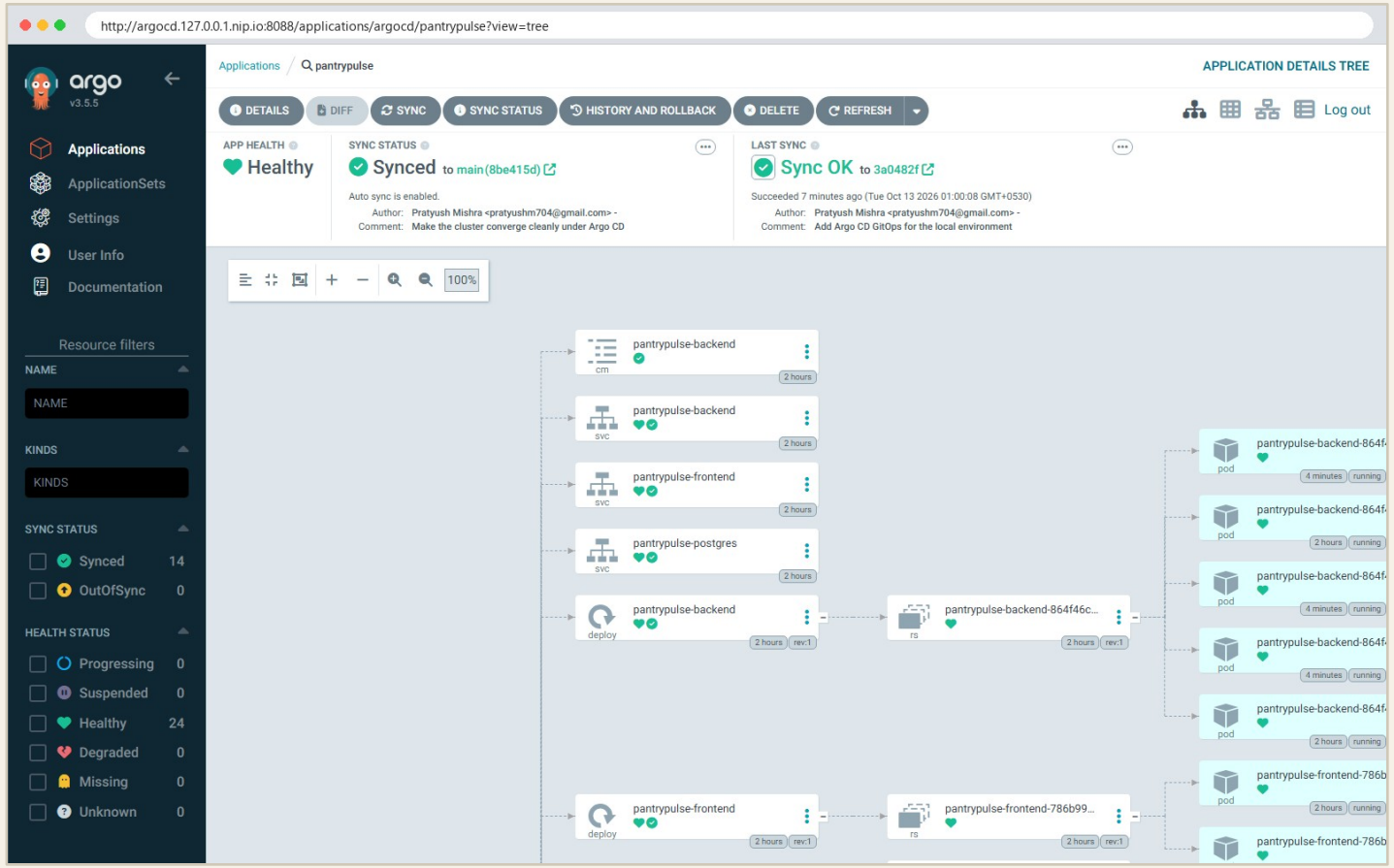
Kubernetes + Helm on kind



- helm upgrade --install with the image SHA required
- Ingress (Traefik): / → frontend, /api → backend
- HPA 2→3→5 at 357% CPU, back to 2 after load
- PostgreSQL StatefulSet · migrate Job per release
- PSA restricted · non-root · read-only rootfs
- Real incidents fixed: Docker Hub DNS, hostPort rollout deadlock
- 4 troubleshooting labs: ImagePullBackOff, empty Service, DB failure, not Ready

GITOPS

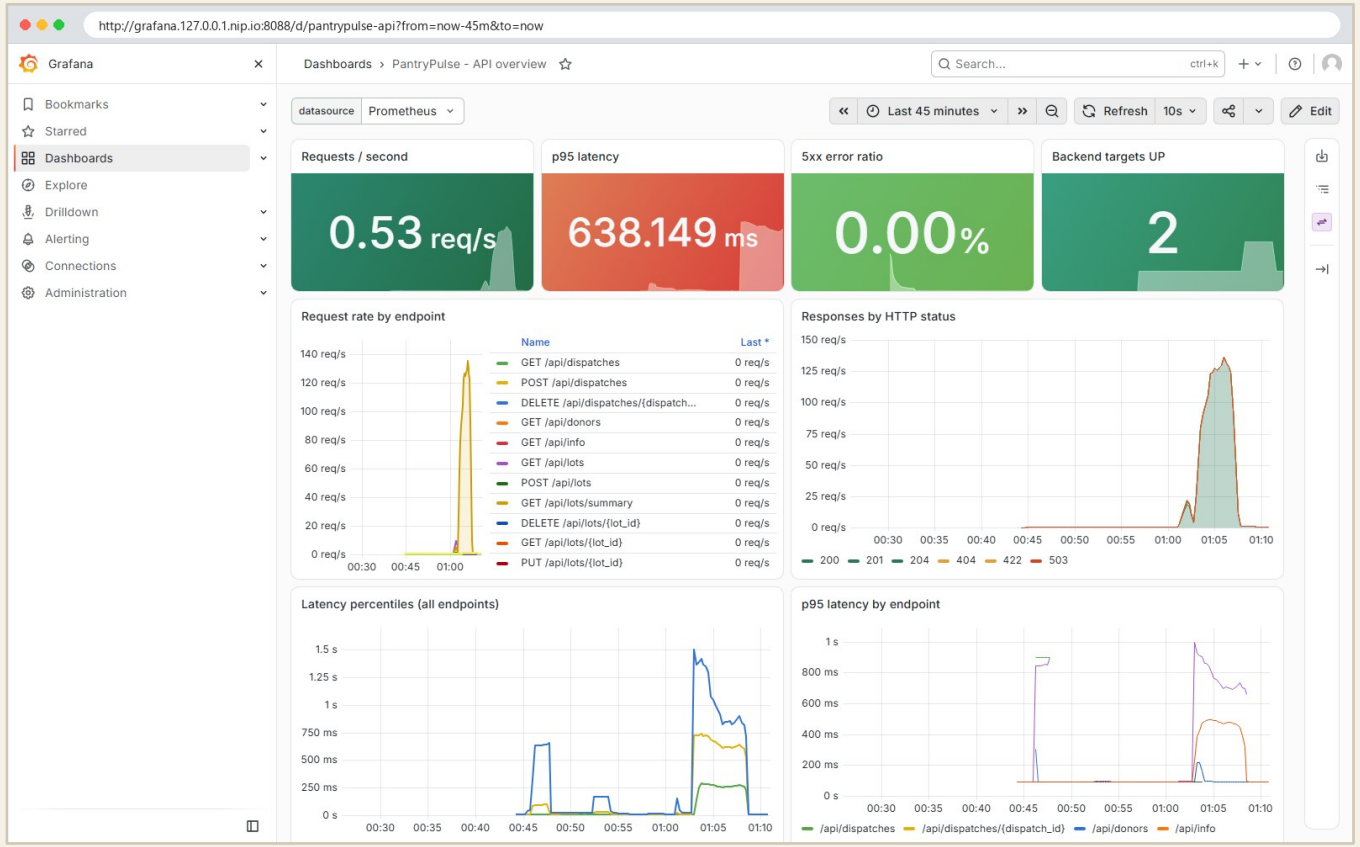
Argo CD: Git is the source of truth

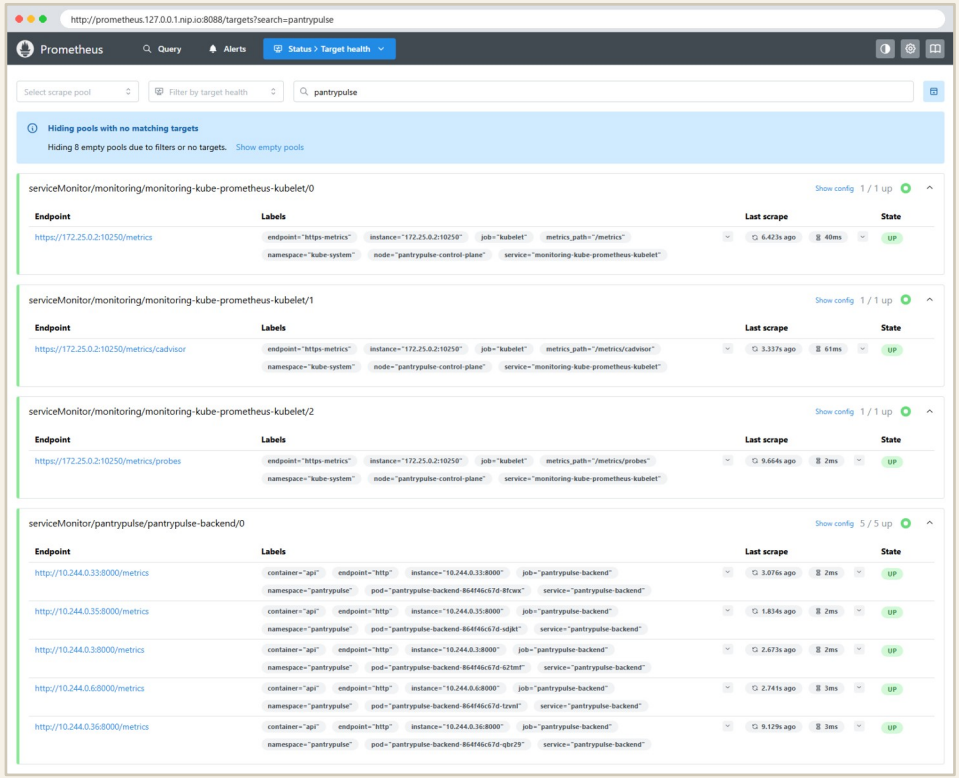


- Automated sync · prune · self-heal
- Promote: scripts/promote.sh <sha> → commit
  - 161f84e → 8be415d (7038d15)
- Rollback: git revert (c1fc74c)
- DB password in a pre-created Secret, never in Git
- Migrations as an Argo CD Sync hook

M9

Observability: Prometheus + Grafana





/metrics · ServiceMonitor 5/5 UP · provisioned dashboard

Found and fixed: Grafana GC thrash (GOMEMLIMIT 345MiB vs 344Mi used)

OPERATIONS

Failure labs and real incidents

Lab 1 — **ImagePullBackOff**
tag never built → set image to a published SHA

Lab 2 — **Service, no endpoints**
selector typo → patch selector

Lab 3 — **Migration can't reach DB**
wrong host → recreate Job

Lab 4 — **Running, never Ready**
/ready 503, no schema → run migrations

Incident — **Docker Hub DNS failure**
first helm install timed out → retry, revision 2

Incident — **Traefik hostPort deadlock**
surge pod Pending → maxSurge 0

Incident — **Grafana GC thrash**
384Mi limit → 768Mi + CPU cap

Incident — **CI caught schema error**
Traefik chart rejects 'logs' key

Every lab and incident has a verbatim transcript in docs/evidence/transcripts.

EVIDENCE

How every claim is backed

- scripts/record.sh runs the command and saves verbatim output (40 transcripts)
- 63 screenshots mapped to rubric modules in docs/evidence/EVIDENCE-MANIFEST.md
- docs/SUBMISSION-CHECKLIST.md: every instructor checklist item with status and link
- 7 ADRs · 4 engineering notes · 4 runbooks (incl. EKS apply/destroy, rollback)
- Pending, stated plainly: AWS apply, console screenshots, terraform destroy

REFLECTION

What I learned

- Scan before you push: a gate after publishing is only a report
- Commit-SHA tags + GitOps turn rollback into git revert
- Readiness that checks the schema keeps half-working pods out of traffic
- Most real failures were platform issues (DNS, host ports, memory limits)
- Write down trade-offs (ADRs) instead of hiding them; be honest about what is pending

Thank you

Next in this video: a live walkthrough of the codebase, CI/CD, Terraform, Argo CD, Kubernetes, Prometheus and Grafana.

github.com/PratyushMishra-2nd/DevopsProject